

Purple Fox EK Relies on Cloudflare for Stability

We've talked about Purple Fox malware being delivered by the Rig exploit kit. Other researchers later found evidence that it had its own delivery mechanism, and thus named it the Purple Fox exploit kit. We recently found a spike in the Purple Fox exploit kit with improved delivering tactics.

By: William Gamazo Sanchez, Joseph C Chen, Elliot Cao
September 09, 2020

Read time: 2 min (660 words)

A year ago, we talked about [Purple Fox malware being delivered by the Rig exploit kit](#). Malwarebytes [later found](#) evidence that it had its own delivery mechanism, and thus named it the Purple Fox exploit kit.

We recently found a spike in the Purple Fox exploit kit with improved delivering tactics in our telemetry. Some of the improvements:

- Use of full HTTPS infrastructure based on Cloudflare as frontend
- Fully encrypted landing page
- Disguised redirection

Once notified, Cloudflare took immediate action to place an interstitial page in front of these domains to disrupt communications. As a result, these particular parts of its infrastructure are no longer online.

The following image shows the Purple Fox EK traffic in the last thirty days before September 3:

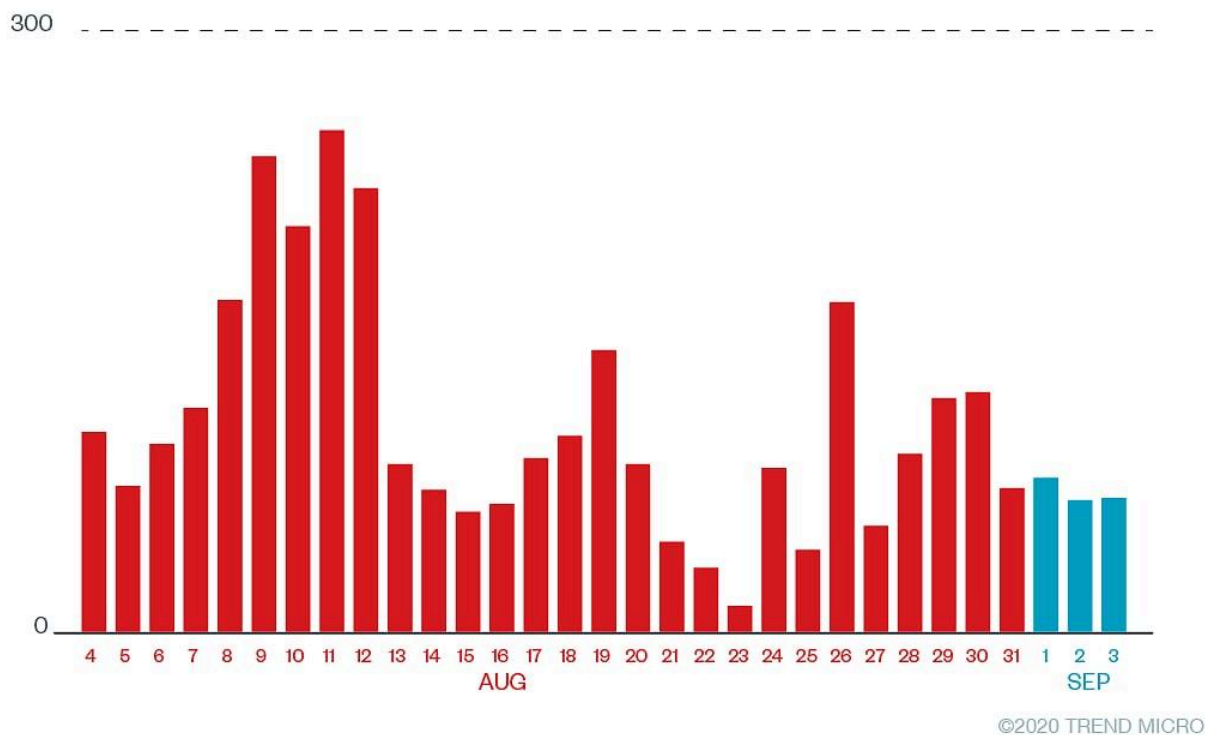


Figure 1. Purple Fox Exploit Kit Traffic

The traffic reflects the number of accessed landing pages and not the unique domains pages.

Landing page in detail

Initially, the victim was redirected to the link <https://{malicious domain}/?key=700D5E232DF5AA21>. Figure 2 shows the full browser session:

Protocol	Body	Content-Type	Host	URL
HTTP	767		Tunnel to	simplegrg.shop:443
HTTPS	25,676	text/html; charset=U...	simplegrg.shop	/?key=700D5E232DF5AA21
HTTPS	47,992	application/javascript	simplegrg.shop	/crypto-js.min.js
HTTPS	1,092	application/javascript	simplegrg.shop	/aes.min.js
HTTPS	9,794	application/javascript	simplegrg.shop	/zepto.min.js
HTTPS	174	application/javascript	simplegrg.shop	/base64.min.js
HTTP	763		Tunnel to	raw.githack.store:443
HTTPS	16	text/plain; charset=U...	raw.githack.store	/brDPCku7PM9TVdRm.jpg

Figure 2. Capturing the redirection via browser session

The domain usually pointed to a Cloudflare front end that is accessible over HTTPS, which allowed the delivery of the exploit kit by default in HTTPS.

104.31.64.32



Error 1003

Ray ID: 5cc9a18a1d010e0e • 2020-09-02 19:27:53 UTC

Direct IP access not allowed

What happened?

You've requested an IP address that is part of the [Cloudflare](#) network. A valid Host header must be supplied to reach the desired website.

What can I do?

If you are interested in learning more about Cloudflare, please [visit our website](#).

Cloudflare Ray ID: 5cc9a18a1d010e0e • Your IP: 176.10.99.200 • Performance & security by [Cloudflare](#)

Figure 3. IP resolves to Cloudflare frontend

The content of the landing page was fully encrypted and obfuscated.

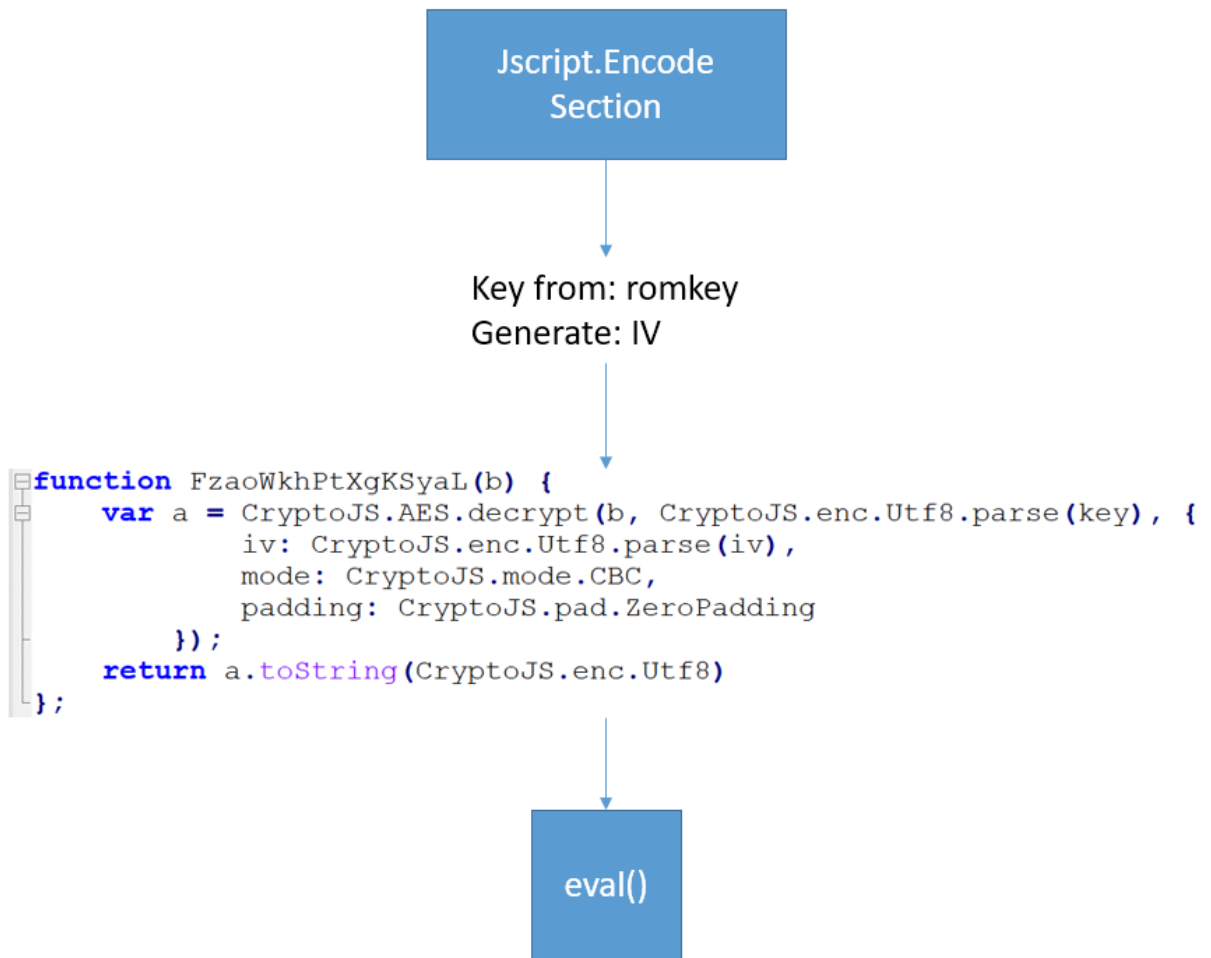


Figure 5. Decryption steps

The landing page has a Jscript.Encode section required for exploiting [CVE-2019-1367](#), as used in this case. The said section initially decrypts the Data1 variable and then executes the content through EVAL().


```
var a = "1.db";  
var b = "2.js";  
var c = 2;  
var d = 2;  
var e = 4;  
var f = 0x10;  
var g = 8;  
var h = 0xC0;  
var i = 0x10;  
var j = 0x38;  
var k = 0x48;  
var l = "\u614E\u4B74\u01c8\u0000\u0000  
\uFFF7\uFFFF\u0000\u0000\uFFFF\uFFF  
\u04FF\uFFEF\uFFFF\uFFF7\uFFFF\u000  
\u000B\u0000\u0000\u0000\uFFFF\uFFF  
\u0000\u0B00\u0000\u0700\u0000\u030  
\u1500\u1312\u0000\u0300\u000D\u000  
\u6100\u6100\u6100\u6100\u6100\u610  
\u6100\u6100\u6100\u6100\u6100\u610  
var m = "\u18E8\u0000\u0000\u0000\u00  
\ub70f\u264a\ufff31\u3cac\u7c61\u2c  
\u75e0\u03f6\uuf87d\u7d3b\u7524\u58e  
\u6f8b\ufff87\ubbd5\u1de0\u0a2a\ua6  
\u2874\u7722\u6373\u6972\u7470\u732  
\u6578\u2063\u7962\u6170\u7373\u2d2  
\u416c\u4d47\u6441\u4141\u4167\u344  
\u4241\u4176\u4547\u5a41\u4241\u415
```

Figure 6. The first section of the exploit

Conclusion

Purple Fox is evolving into a modern exploit kit that delivers landing pages over HTTPS and reusing secure public cloud infrastructure. While the use of encrypted landing pages is not new in exploit kits and the [abuse of public clouds like Cloudflare](#) is not uncommon, the use of such pages allows exploit kits to bypass many existing protections.

Best Practices and Trend Micro solutions

Purple Fox exploits vulnerabilities with available patches, as seen in the sample we analyzed here. This highlights the significance of patching, especially for enterprises. We recommend a defense-in-depth approach to securing online infrastructures. Here are some best practices that users and organizations can adopt:

- Enforce the principle of least privilege by restricting and securing the use of tools reserved for system administrators.
- Regularly patch and update (or employ virtual patching for legacy or embedded systems or software).
- Deploy additional mechanisms that provide additional layers of security, such as behavior monitoring, which thwarts malware-related routines from being executed in the system; sandboxes, which can quarantine malicious files and further analyze suspicious behaviors; and firewalls and intrusion prevention and detection systems that can deter incursions or flag data exfiltration attempts.
- Cultivate cybersecurity awareness at home and in the workplace, especially against email-borne threats that fileless threats could use as attack vectors or entry points.

Trend Micro endpoint solutions such as the Smart Protection Suites and Worry-Free Business Security solutions, which have behavior monitoring capabilities, can protect users and businesses from these types of threats by detecting malicious files, scripts, and messages as well as blocking all related malicious URLs. Trend Micro Apex One™ protection employs a variety of threat detection capabilities, notably behavioral analysis, which protect against malicious scripts, injection, ransomware, memory, and browser attacks related to fileless threats.

Indicators of Compromise

SHA256	Trend Micro Detection
C0969831BB6020565A706F836A1FC303DD8874CB42C7792CD931B77C3FF49B6D	Trojan.JS.CVE20191367.C

Malicious URLs

- [hxxps://action.taplowgroup.club/?key=9387A593E49317F4](https://action.taplowgroup.club/?key=9387A593E49317F4)
- [hxxps://grgatm.xyz/?key=B07A0B81A81AA904](https://grgatm.xyz/?key=B07A0B81A81AA904)